

HOW TO BECOME A GRC ANALYST

A practical guide to governance, risk, compliance, audit readiness, and career preparation

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Table of contents

- Purpose and responsible use
- 1. What a GRC analyst does
- 2. Career levels and progression
- 3. Core knowledge
- 4. Frameworks and standards
- 5. Risk assessment method
- 6. Controls and control testing
- 7. Evidence collection
- 8. Policy and procedure writing
- 9. Audit readiness
- 10. Third-party risk
- 11. Cloud and AI governance
- 12. Tools
- 13. Communication
- 14. Portfolio projects
- 15. Resume and interviews
- 16. 30-60-90 day learning plan
- 17. Practical templates / Plantillas practicas
- 18. Official references / Referencias oficiales

Purpose and responsible use

This manual helps beginners and career changers understand the work of a Governance, Risk, and Compliance analyst and build practical, ethical portfolio evidence. It does not replace legal advice, certification training, or organization-specific policy.

Use only fictional, sanitized, or authorized information in exercises and portfolios. Never place confidential company data, personal information, credentials, audit evidence, or regulated records in a public repository.

1. What a GRC analyst does

A GRC analyst connects business objectives, technology, risk, controls, evidence, and accountability. The work is not simply completing checklists. It requires understanding why a control exists, how it reduces risk, whether it operates effectively, and how to communicate gaps without creating unnecessary conflict.

Common responsibilities include risk assessments, control mapping, evidence review, policy support, audit coordination, issue tracking, third-party risk, compliance monitoring, metrics, and executive reporting.

2. Career levels and progression

Entry-level analysts often collect evidence, maintain registers, support assessments, update documentation, and track remediation. Mid-level analysts lead assessments and control testing. Senior professionals design programs, advise executives, manage regulatory obligations, and integrate cyber risk with enterprise risk.

3. Core knowledge

Learn basic cybersecurity, networking, cloud, identity, data protection, vulnerability management, incident response, business continuity, privacy, and audit concepts. A GRC analyst does not need to be the deepest technical specialist, but must ask precise questions and recognize when technical evidence is incomplete.

4. Frameworks and standards

Start with NIST CSF 2.0, ISO/IEC 27001, CIS Controls, SOC 2 concepts, PCI DSS when payment data is relevant, HIPAA when applicable, privacy obligations, and NIST AI RMF for AI-related risk. Do not claim compliance without understanding scope, evidence, exceptions, and operating effectiveness.

5. Risk assessment method

A practical assessment identifies assets, threats, vulnerabilities, existing controls, likelihood, impact, risk owner, treatment, due date, and residual risk. Use a consistent scale and explain assumptions. Avoid false precision.

Field	Example
Risk	Unauthorized access to customer data
Asset	Customer database
Threat	Compromised account
Weakness	No phishing-resistant MFA
Likelihood	Possible
Impact	High
Treatment	Implement stronger MFA and access monitoring
Owner	Identity service owner
Residual risk	Medium after validation

6. Controls and control testing

A control should have a clear objective, owner, frequency, procedure, evidence, population, and exception process. Design effectiveness asks whether the control could reduce the risk. Operating effectiveness asks whether it actually operated as intended during the review period.

Control element	Question
Objective	What risk does it reduce?
Owner	Who is accountable?
Frequency	How often?
Evidence	What proves operation?
Population	What systems or users are covered?
Exception	How are failures recorded?

7. Evidence collection

Good evidence is relevant, reliable, complete, time-bound, attributable, and protected. Examples include approved policies, configuration exports, access-review records, tickets, screenshots with context, training records, logs, meeting approvals, and system reports.

8. Policy and procedure writing

Policies state management expectations. Standards establish mandatory requirements. Procedures explain how work is performed. Guidelines provide recommended practices. Keep documents

readable, assign owners, define review cycles, and avoid copying requirements that the organization cannot operate.

9. Audit readiness

Maintain a request list, evidence owner, due date, status, reviewer, exception, and final disposition. Prepare evidence before an audit, but never manufacture or backdate records. Be transparent about gaps and document corrective action.

10. Third-party risk

Assess the service, data, connectivity, criticality, geographic exposure, subcontractors, resilience, incident obligations, and contract protections. A questionnaire alone is not sufficient for high-risk suppliers.

11. Cloud and AI governance

For cloud, understand shared responsibility, identities, logging, encryption, network exposure, backups, and configuration management. For AI, maintain an inventory, purpose, data classification, risk tier, human oversight, evaluation evidence, vendor review, monitoring, and incident process.

12. Tools

Common tools include spreadsheets, ticketing platforms, GRC platforms, document repositories, vulnerability scanners, SIEM reports, cloud security dashboards, Microsoft Purview, Defender for Cloud, Vanta, Drata, ServiceNow GRC, Archer, OneTrust, and open-source tools. Learn the process before the platform.

13. Communication

Write findings that explain condition, criteria, cause, risk, recommendation, owner, and due date. Separate fact from assumption. Use respectful language. Present executives with business impact and decisions, not raw technical detail.

14. Portfolio projects

Create sanitized examples: a risk register, control matrix, policy, vendor assessment, audit request tracker, incident tabletop report, cloud risk review, AI system inventory, and executive dashboard. Include a README explaining purpose, scope, assumptions, and ethical limitations.

- Risk register / Registro de riesgos
- Control matrix / Matriz de controles

- Evidence request tracker / Seguimiento de evidencia
- Third-party assessment / Evaluacion de terceros
- Executive risk summary / Resumen ejecutivo

15. Resume and interviews

Show outcomes, scope, frameworks, evidence, and collaboration. Do not invent audits, certifications, or regulated experience. Prepare examples using Situation, Task, Action, and Result. Be ready to explain how you handle missing evidence, disagreements, overdue remediation, and ambiguous requirements.

16. 30-60-90 day learning plan

Days 1-30: learn risk, controls, evidence, NIST CSF 2.0, and basic cybersecurity. Days 31-60: complete portfolio artifacts and practice control testing. Days 61-90: conduct a fictional end-to-end assessment, improve communication, and apply for roles.

17. Practical templates / Plantillas practicas

Sample finding

Condition: Quarterly access reviews were not completed for two production applications. Criteria: The access review standard requires quarterly review. Risk: Inappropriate access may remain active. Recommendation: Complete the review, remove unnecessary access, identify the cause, and monitor future completion. Owner and due date: Assigned by management.

Evidence tracker fields

- Request ID
- Control
- Requested evidence
- Owner
- Due date
- Status
- Reviewer
- Exception
- Final conclusion

Human safety and professional ethics

Never shame people for a control failure. Focus on systems, decisions, evidence, risk, and improvement. Escalate urgent threats responsibly. Protect personal information and confidential evidence.

18. Official references / Referencias oficiales

[NIST Cybersecurity Framework 2.0](#)

[NIST CSF 2.0 publication](#)

[NIST AI Risk Management Framework](#)

[ISO/IEC 27001 overview](#)

[PCI DSS v4.0.1](#)

[CIS Critical Security Controls](#)

[OWASP Foundation](#)

License / Licencia

Copyright © 2026 Alberto (Al) Leiva. CC BY-NC-SA 4.0.